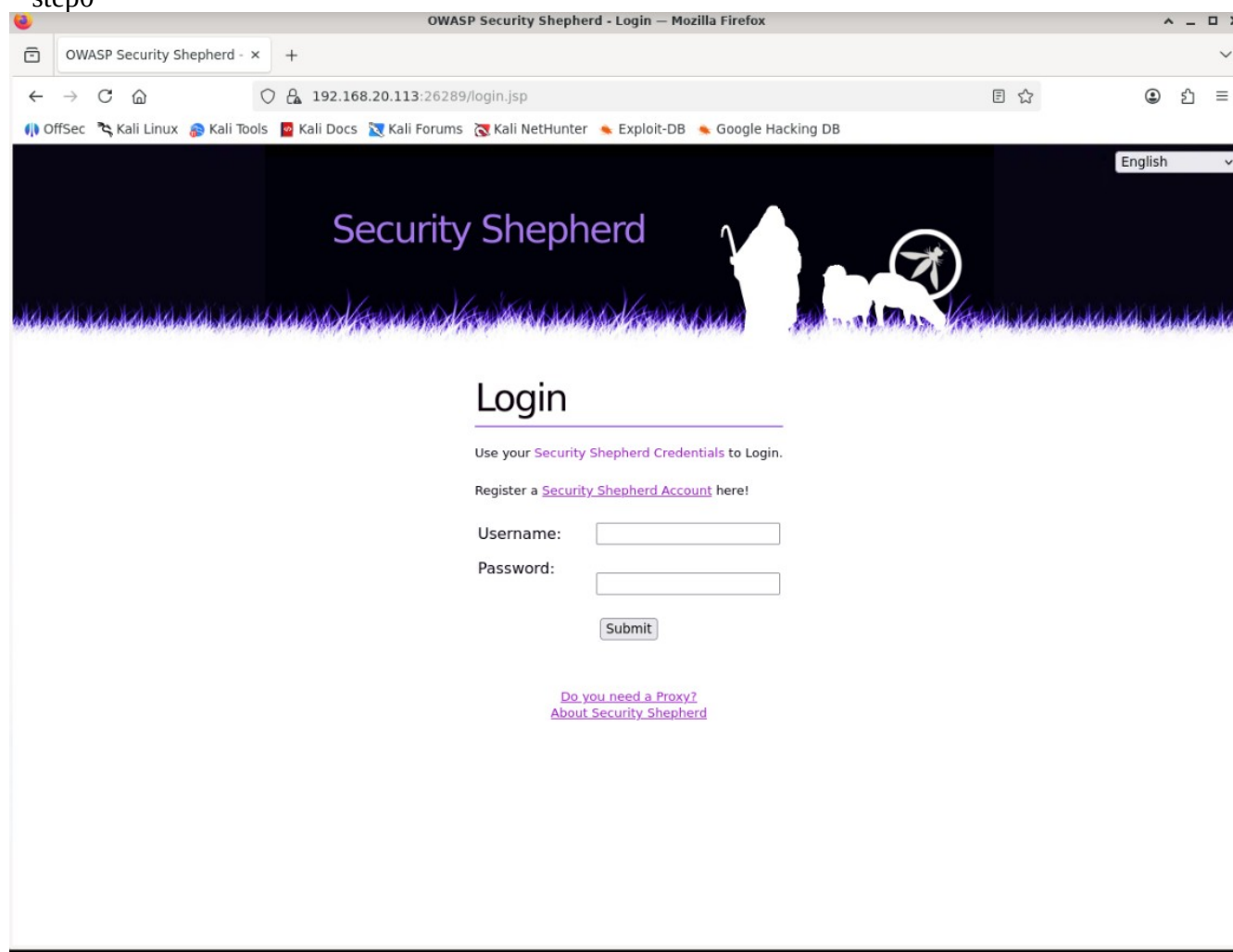


Security Speherd

```
student@kali:~$ nmap -p- 192.168.20.113
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 14:39 +0000
Nmap scan report for sclab-s2-proxy.sclab_labnet (192.168.20.113)
Host is up (0.0000090s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
26289/tcp  open  unknown
MAC Address: 76:FE:83:AB:8E:05 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.10 seconds
```

step0



OWASP Security Shepherd - Login — Mozilla Firefox

OWASP Security Shepherd - x

192.168.20.113:26289/login.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

English

Security Shepherd

Login

Use your [Security Shepherd Credentials](#) to Login.

Register a [Security Shepherd Account](#) here!

Username:

Password:

[Do you need a Proxy?](#)
[About Security Shepherd](#)

step1- register

OWASP Security Shepherd - Register — Mozilla Firefox

OWASP Security Shepherd - x +

192.168.20.113:26289/register.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

English

Security Shepherd

Register

Username* :

Password* :

Confirm Password* :

Email Address:

Confirm Email:

SHEPHERD DISCLAIMER

The Security Shepherd project is for educational purposes only. Do not attempt to use these techniques without authorization. If you are caught engaging in unauthorized hacking, most companies will take legal action. Claiming that you were doing security research will not protect you.

Security Shepherd is a safe playground for you to improve your web application security skills and only encourages white hat or ethical hacking behaviour.

step2- login after login click on nxt challenge

Challenge1-Broken auth d session mgt

press f12 then move to storage tab, click on cookies go to whatever ur ip here pointed out with blue clr

Name	value
lessoncomplete	lessonnotcomplete

change value to lessonComplete nd then leave

OWASP Security Shepherd — Mozilla Firefox

192.168.20.113:26289/index.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Scoreboard

Get Next Challenge

Search Modules...

Submit Result Key Here... Submit

What is Broken Authentication and Session Management?

Attacks against an application's **authentication** and **session management** can be performed using security risks that other vulnerabilities present. For example, any application's session management can be overcome when a **Cross Site Scripting** vulnerability is used to steal user session tokens. This topic is more about flaws that exist in the applications authentication and session management schema.

Broken authentication and session management flaws are commonly found in functionalities such as logout, password management, secret question and account update. An attack can potentially abuse these functions to modify other users credentials by guessing their secret question or through parameter abuse. Finding such flaws can sometimes be difficult, as each implementation is unique.

The following scenarios are vulnerable to these security risks:

- 1) User credentials are **stored** with insufficient **cryptographic** levels.
- 2) User credentials can be guessed or changed through poor **account management**.
- 3) Session identifiers are exposed in the URL.
- 4) The application does not use sufficient transport protection (Such as **HTTPs** or **sFTP**).
- 5) Session parameters can be manually changed by the user through application functionality.

Session parameters can be manually changed by the user through application functionality.

[Hide Lesson Introduction](#)

This lesson implements bad session management. Investigate the following function to see if you trick the server into thinking you have already completed this lesson to retrieve the result key.

Inspector Console Debugger Network Style Editor Performance Memory **Storage** Accessibility Application

Cache Storage Cookies Indexed DB Local Storage Session Storage

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
JSESSIO...	86A46885E75FD...	192.168.2...	/	Session	42	true	true	None	Tue, 19 May 202...
lessonC...	lessonComplete	192.168.2...	/lessons	Session	31	false	false	None	Tue, 19 May 202...
token	8434780642080...	192.168.2...	/	Session	42	false	true	None	Tue, 19 May 202...

Filter values

lessonComplete:"lessonNotComplete"

Created:"Tue, 19 May 2026 14:42:38 GMT"

Domain:"192.168.20.113"

Expires / Max-Age:"Session"

HostOnly:true

HttpOnly:false

Last Accessed:"Tue, 19 May 2026 14:42:38 GMT"

Path:"/lessons"

SameSite:"None"

nd press complete this lesson after that res key generated copy it

OWASP Security Shepherd — Mozilla Firefox

192.168.20.113:26289/index.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

logout, password management, secret question and account update. An attack can potentially abuse these functions to modify other users credentials by guessing their secret question or through parameter abuse. Finding such flaws can sometimes be difficult, as each implementation is unique.

The following scenarios are vulnerable to these security risks;

- 1) User credentials are stored with insufficient cryptographic levels.
- 2) User credentials can be guessed or changed through poor account management.
- 3) Session identifiers are exposed in the URL.
- 4) The application does not use sufficient transport protection (Such as HTTPS or SFTP).
- 5) Session parameters can be manually changed by the user through application functionality.

Session parameters can be manually changed by the user through application functionality.

[Hide Lesson Introduction](#)

This lesson implements bad session management. Investigate the following function to see if you trick the server into thinking you have already completed this lesson to retrieve the result key.

[Complete This Lesson](#)

Lesson Complete

Congratulations, you have bypassed this lessons **VERY WEAK** session management. The result key for this lesson is

CA734AD354B1A3A7E35C9FECF4AF30254541D4752E1372A6A4704

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Cache Storage Cookies Indexed DB Local Storage Session Storage

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
JSESSIONID	86A46885E75FD...	192.168.2...	/	Session	42	true	true	None	Tue, 19 May 202...
lessonC...	lessonNotCompl...	192.168.2...	/lessons	Session	31	false	false	None	Tue, 19 May 202...
token	8434780642080...	192.168.2...	/	Session	42	false	true	None	Tue, 19 May 202...

lessonComplete:"lessonNotComplete"

Created:"Tue, 19 May 2026 14:42:38 GMT"

Domain:"192.168.20.113"

Expires / Max-Age:"Session"

HostOnly:true

HttpOnly:false

Last Accessed:"Tue, 19 May 2026 14:44:18 GMT"

Path:"/lessons"

SameSite:"None"

put res key in respective bar nd submit nd get nxt challenge

OWASP Security Shepherd — Mozilla Firefox

192.168.20.113:26289/index.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1ms23cs168 | Logout English

Security Shepherd

Scoreboard

Get Next Challenge

Search Modules...

2F35E13660A3C85D370D32F53526D2CACE2A8314633E46B93C12F167EF194A4B1DAC115 Submit

What is Broken Authentication and Session Management?

Attacks against an application's **authentication** and **session management** can be performed using security risks that other vulnerabilities present. For example, any application's session management can be overcome when a **Cross Site Scripting** vulnerability is used to steal user session tokens. This topic is more about flaws that exist in the applications authentication and session management schema.

Broken authentication and session management flaws are commonly found in functionalities such as logout, password management, secret question and account update. An attack can potentially abuse these functions to modify other users credentials by guessing their secret question or through parameter abuse. Finding such flaws can sometimes be difficult, as each implementation is unique.

The following scenarios are vulnerable to these security risks:

- 1) User credentials are **stored** with insufficient **cryptographic** levels.
- 2) User credentials can be guessed or **changed** through poor **account management**.

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Cache Storage Cookies Indexed DB Local Storage Session Storage

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
JSESSIONID	86A46885E75FD...	192.168.2...	/	Session	42	true	true	None	Tue, 19 May 202...
lessonComplete	lessonNotComplete	192.168.2...	/lessons	Session	31	false	false	None	Tue, 19 May 202...
token	8434780642080...	192.168.2...	/	Session	42	false	true	None	Tue, 19 May 202...

Filter values

lessonComplete: "lessonNotComplete"

Created: "Tue, 19 May 2026 14:42:38 GMT"

Domain: "192.168.20.113"

Expires / Max-Age: "Session"

HostOnly: true

HttpOnly: false

Last Accessed: "Tue, 19 May 2026 14:44:18 GMT"

Path: "/lessons"

SameSite: "None"

challeng 2 XSS

copy the respective 1st cmd d put search bar shown below

OWASP Security Shepherd — Mozilla Firefox

OWASP Security Shepherd

192.168.20.113:26289/index.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Scoreboard

Completed

Get Next Challenge

Search Modules...

Submit Result Key Here...

Submit

What is Cross Site Scripting (XSS)?

Cross-Site Scripting, or **XSS**, issues occur when an application uses **untrusted data** in a web browser without sufficient **validation** or **escaping**. If untrusted data contains a client side script, the browser will execute the script while it is interpreting the page.

Attackers can use XSS attacks to execute scripts in a victim's browser which can hijack user sessions, deface web sites, or redirect the user to malicious sites. Anyone that can send data to the system, including administrators, are possible candidates for performing XSS attacks in an application.

According to OWASP, XSS is the most widespread vulnerability found in web applications today. This is partially due to the variety of **attack vectors** that are available. The easiest way of showing an XSS attack executing is using a simple **alert box** as a client side script pay load. To execute a XSS payload, a variety of an attack vectors may be necessary to overcome insufficient escaping or validation. The goal is to all create the same **alert** pop up that reads

192.168.20.113:26289

XSS

OK

Hide Lesson Introduction

The following search box outputs untrusted data without any validation or escaping. Get an alert box to execute through this function to show that there is an XSS vulnerability present.

Please enter the **Search Term** that you want to look up

<SCRIPT>alert('XSS')</SCRIPT>

Loading...

OWASP Security Shepherd — Mozilla Firefox

192.168.20.113:26289/index.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1ms23cs168 | Logout English

Security Shepherd

Scoreboard

Completed

Get Next Challenge

Search Modules...

B1666CC6E306454EAD745A20439C59988FEEC164ADA74F770B2EB6282AFF85C29E150CD Submit

What is Cross Site Scripting (XSS)?

Cross-Site Scripting, or **XSS**, issues occur when an application uses **untrusted data** in a web browser without sufficient **validation** or **escaping**. If untrusted data contains a client side script, the browser will execute the script while it is interpreting the page.

Attackers can use XSS attacks to execute scripts in a victim's browser which can hijack user sessions, deface web sites, or redirect the user to malicious sites. Anyone that can send data to the system, including administrators, are possible candidates for performing XSS attacks in an application.

According to OWASP, XSS is the most widespread vulnerability found in web applications today. This is partially due to the variety of **attack vectors** that are available. The easiest way of showing an XSS attack executing is using a simple **alert box** as a client side script pay load. To execute a XSS payload, a variety of an attack vectors may be necessary to overcome insufficient escaping or validation. The following are examples of some known attack vectors, that all create the same **alert** pop up that reads "XSS".

```
<SCRIPT>alert('XSS')</SCRIPT>
<IMG SRC="# ONERROR=alert('XSS')"/>
<INPUT TYPE="BUTTON" ONCLICK=alert('XSS')"/>
<IFRAME SRC="javascript:alert('XSS');"></IFRAME>
```

Hide Lesson Introduction

The following search box outputs untrusted data without any validation or escaping. Get an alert box to execute through this function to show that there is an XSS vulnerability present.

Please enter the **Search Term** that you want to look up

challenge 3 – Cross site scripting one

copy cmd put on res bar shown below

OWASP Security Shepherd — Mozilla Firefox

OWASP Security Shepher x +

192.168.20.113:26289/index.jsp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Scoreboard

Completed

Get Next Challenge

Search Modules...

Submit Result Key Here...

Submit

Cross Site Scripting One

Find a XSS vulnerability in the following form. It would appear that your input is been filtered!

Please enter the **Search Term** that you want to look up

<img src=x onerror=alert(XSS)|

Get this user